

# BEC INVESTIGATION REPORT

SOC Simulation Project // WDLabs // Microsoft 365 UAL Investigation

## Case Details

|                     |                                                                        |
|---------------------|------------------------------------------------------------------------|
| Case Name           | Project Victoria                                                       |
| Affected Account(s) | Naomi Hunter (targeted counterparty),<br>Donald Anderson (compromised) |
| Incident Date Range | 2026-03-07 — 2026-03-15                                                |
| Investigation Date  | 2026-03-15                                                             |
| Analyst             | Kristijan                                                              |

## Attack Narrative (Executive Summary)

Between 7 and 10 March 2026, an unauthorised party gained access to the email account of Donald Anderson and used it to attempt a business email compromise (BEC) — a fraud in which an attacker, operating from a legitimate internal account, conducts deceptive correspondence with a third party. Over this period the account was accessed from multiple external IP addresses inconsistent with the user's normal activity.

Early in the intrusion, the attacker created a hidden mailbox rule designed to conceal incoming replies from the targeted correspondent (Naomi Hunter), ensuring the legitimate account owner would not see the fraudulent exchange. The attacker then accessed and downloaded a number of files from SharePoint, created and sent an email titled "Report" from the compromised account, and subsequently deleted the sent message to avoid detection — behaviour consistent with a deliberate, staged operation rather than opportunistic access.

The activity went undetected for approximately five days until 15 March 2026, when a suspicious email reported to the administrator prompted investigation. The compromised account was contained and its password reset. The mechanism of initial access and whether any downloaded data left the environment remain under review.

## Timeline of Events

| Time (GMT 10+)               | Activity                                             | Detail                                                                                                                                                                   |
|------------------------------|------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 7 March 2026<br>12:49:55 PM. | First unauthorised sign-in using the Donald account. | IP: 54[.]206[.]1115[.]107<br>Client: donald[.]anderson[.]@wdlabs[.]com[.]au<br>Extra contexts: Signed in via OWA, opening the Donald account mailbox for initial access. |

| Time (GMT 10+)                              | Activity                                                                        | Detail                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|---------------------------------------------|---------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 9 March 2026<br>5:01:07 PM –<br>5:10:45 PM. | Donald's account accessed 5 emails.                                             | IP: 91[.]217[.]249[.]193<br>Client: donald[.]anderson[@]wdlabs[.]com[.]au<br>Extra contexts: Donald account observed accessing multiple different emails to observe for reconnaissance to gather information about the victim asset.                                                                                                                                                                                                                                                                          |
| 9 March 2026<br>5:10:45 PM                  | Among emails being accessed Donald account created new Inbox Rule               | IP: 91[.]217[.]249[.]193:17130<br>Client: donald[.]anderson[@]wdlabs[.]com[.]au<br>Extra contexts: Email rule was created called “.” to move emails from Naomi account to RSS feeds and Mark as Read. This means if Donald glanced at the folder list, nothing would draw his eye.<br><br>Additionally, the unauthorised party made sure to prevent further rules from applying to surface the mail when it has been intentionally hidden by this first rule. <a href="#">T1564.008 —(Email Hiding Rules)</a> |
| 09 March 2026<br>5:20:28 PM –<br>5:26:38 PM | Donald's account accessed the company SharePoint                                | IP: 45[.]133[.]5[.]24<br>Client: donald[.]anderson[@]wdlabs[.]com[.]au<br>Extra contexts: The Donald account searched and downloaded various company SharePoint files.                                                                                                                                                                                                                                                                                                                                        |
| 10 March 2026<br>7:33:45 PM                 | Donald's account authored an unauthorised email                                 | IP: 104[.]234[.]32[.]142<br>Client: donald[.]anderson[@]wdlabs[.]com[.]au<br>Extra contexts: The Donald account created a email with Exchange Item ID “LgAAAAB7v8sIKtVETrcRaS1f5gjaAQADbzp KDkyFTZHbmG6YAd29AAAAAAEPAAAB” in the Drafts folder of the Donald account mailbox.                                                                                                                                                                                                                                 |
| 10 March 2026<br>7:43:34PM –<br>7:44:37PM   | Donald's account accessed SharePoint and viewed recently used/created documents | IP: 173[.]239[.]229[.]83<br>Client: donald[.]anderson[@]wdlabs[.]com[.]au<br>Extra contexts: The Donald account performed reconnaissance against SharePoint, using Donald's recent-document history to identify high-value content and enumerating SitePages by author to map internal roles and relationships which is consistent with target selection for a Business Email Compromise.<br><a href="#">T1213 — Data from Information Repositories</a><br><a href="#">T1087 — Account Discovery</a>          |
| 10 March 2026<br>7:51:40 PM                 | Suspicious email sent                                                           | An email titled ‘Report’ was sent from the account (Send), from 104[.]234[.]32[.]143. The                                                                                                                                                                                                                                                                                                                                                                                                                     |

| Time (GMT 10+)              | Activity          | Detail                                                                                                                                                                 |
|-----------------------------|-------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                             |                   | fraudulent message to the counterparty<br>Naomi Hunter appears to be the objective of the BEC.                                                                         |
| 10 March 2026<br>8:15:56 PM | Sent item deleted | An item was moved to Deleted Items (MoveToDeletedItems), from 104[.]234[.]32[.]143. Send-then-delete is concealment, consistent with the earlier inbox-rule behaviour. |
| 15 March 2026<br>3:07:37 PM | Detection         | Admin Dalan began investigating a report of a suspicious email from Donald Anderson to Naomi Hunter. ~5 days between last attacker activity (10 Mar) and detection.    |
| —                           | Remediation       | Account password reset. Remediation actions completed (no log timestamp — response action, not an observed attack event).                                              |

# CHRONOLOGY OF INITIAL COMPROMISE

*Project Victoria – BEC Investigation Timeline*

07 / 03 / 2026

## Account First Accessed

First observed unauthorised activity at **12:49:55 PM**. The session authenticated as the Donald account via Outlook Web App (OWA) and accessed 5 mail items, from 54[.]206[.]115[.]107.

*Assessment: earliest confirmed malicious access. Initial access vector not established from available logs.*

09 / 03 / 2026

## Mailbox Access Resumes

At **5:01:07 PM** the session resumed accessing mailbox items (MailItemsAccessed) from 91[.]217[.]249[.]193.

*Assessment: reconnaissance of mailbox contents prior to establishing persistence.*

## Unauthorised Inbox Rule Created

At 5:10:45 PM a New-InboxRule operation created a mail rule targeting messages from Naomi Hunter, from 91[]217[]249[]193:17130.

*Assessment: persistence/concealment established before any outbound mail – preparatory, to hide the counterparty's replies from the legitimate user.*

## SharePoint Files Downloaded

From 5:20:28 PM–5:26:38 PM the session previewed and accessed numerous SharePoint items and **downloaded 12 PDF files**, from 45[]133[]5[]24 and 45[]133[]5[]15.

*Assessment: strongest evidence of potential data exfiltration. Downloads are full retrievals, distinct from preview/view events. File contents not determinable from logged filenames.*

10 / 03 / 2026

## Unauthorised Email Creation

At 7:33:45 PM the session created an email item as the user (Create), from 104[]234[]32[]142.

*Assessment: consistent with staging the fraudulent message.*

## Further SharePoint Activity

7:43:34–7:44:37 PM: viewed recently used documents and SitePages by author, and downloaded one further PDF, from 173[]239[]229[]83.

*Assessment: continued enumeration; same file as 9 Mar re-downloaded from a different source IP.*

## Suspicious Email Sent

At 7:51:40 PM an email titled 'Report' was sent from the account (Send), from 104[.]234[.]32[.]143.

*Assessment: the fraudulent message to the counterparty; objective of the BEC.*

## Sent Item Deleted

At 8:15:56 PM an item was moved to Deleted items (MoveToDeletedItems), from 104[.]234[.]32[.]143.

*Assessment: send-then-delete is concealment – removing the sent message from view, consistent with the earlier inbox-rule behaviour.*

15 / 03 / 2026

## Detection & Remediation

At 3:07:37 PM Admin Dalan began investigating a report of a suspicious email from Donald Anderson to Naomi Hunter. The account password was subsequently reset.

*~5 days between last attacker activity (10 Mar) and detection (15 Mar) – attacker dwell time.*

*All indicators defanged for safe handling.*

*Times shown as logged (Local Time). Findings stated from telemetry; italicised "Assessment" notes are analytic judgement.*

## Findings

---

### 3.1 Initial Access

On 7 March 2026 12:49:55 PM GMT10+, the first unauthorised sign-in to the Donald Account from IP address 54[.]206[.]115[.]107 (AWS IP) via Outlook Web App (OWA).

Following authentication, the session accessed five email items.  
The sign-in originated from infrastructure inconsistent with the account's established baseline.

### 3.2 Unauthorised Activity

On 9 March 2026 at 5:10:45 PM GMT10+ the Donald Account created a new inbox rule named “.”. From the IP address 91[.]217[.]249[.]193 (Germany, Berlin – VPN provider) The inbox rule moved all incoming emails from [Naomi.Hunter@wdlabs.com.au](mailto:Naomi.Hunter@wdlabs.com.au) marked them as read and moved them to the 'RSS Feeds' folder. **[Comment:** The inbox rule was created before any unauthorised outbound email was observed, indicating it was established preparatory to the fraudulent activity rather than in reaction to it. By automatically removing Naomi Hunter's incoming messages from view, the rule ensured that once the unauthorised party began corresponding with Naomi using the Donald account, the legitimate account holder would not see her replies — allowing the fraudulent exchange to continue undetected. ]

### 3.3 Data Access

Two days after initial access, on 9 March 2026, the unauthorised party authenticated as the Donald account conducted the most significant data-access activity of the incident. Between 5:20 PM and 5:26 PM, the session performed a series of SharePoint/OneDrive operations recorded as FilePreviewed (16 events), FileAccessed (17 events) and, most significantly, FileDownloaded (13 events) — twelve files downloaded from IP 45[.]133[.]5[.]24 and 45[.]133[.]5[.]15 on 9 March, and one further download from 173[.]239[.]229[.]83 on 10 March.

On the mail side, MailItemsAccessed events were recorded across 7–10 March (8 events), consistent with the session reading mailbox contents. On 10 March the session also created an item (7:33:45 PM), sent an item (Send, 7:51:40 PM) and subsequently moved an item to Deleted Items (MoveToDeletedItems, 8:15:56 PM).

**[Comment:** The volume and clustering of FileDownloaded events represents the clearest evidence of potential exfiltration in the incident — these are full file retrievals, distinct from the FilePreviewed/FileAccessed events which indicate viewing only. The Send followed by MoveToDeletedItems on 10 March is consistent with the unauthorised party sending mail from the account and then deleting it from the Sent/visible folders to conceal the activity, consistent with the earlier inbox-rule concealment behaviour.]

## Lessons Learned

---

I think I learned a lot about how to do a proper investigation and putting it into a report that is detailed. I accept my documentation is good but the way I do it (template it) needs to be better. To me the important thing is to learn the process, improve the process and make sure its replicable. And then (ideally) to automate the process.

I learned a great deal about the different views in Sentinel and where to look for indicators of compromise. I used my natural curiosity to correlate different pieces of information like time, date, client ip, location, with public resources like abuseipdb or ip-api to a known indicator of compromise and used that to inform the rest of my investigation.

I learned a lot about how to use KQL and how to correlate different bits of useful information in Sentinel's KQL to search for additional instances of malicious activity that would not have been possible if I didn't double check for additional activity performed by client session IDs.

I think what I would do differently is create & use a findings/reporting template so that I can inform future investigations more cleanly and more effectively.

Obsidian is fine for note-taking, but I need to perhaps focus on translating the Excel spreadsheets I curate into something that explains itself better, not just looks pretty.

And to provide that additional context throughout instead of a little bit here and little bit there.

And I learned about defanging IPs to prevent accidental clicks on malicious URLs during threat analysis.

Lastly, A middle-ground KQL trick if I want readable output without losing fields: use ``project-reorder`` or ``project-away`` instead. ``project-reorder TimeGenerated, Operation, UserId, ClientIP`` puts the columns I care about first but keeps everything else still hanging off the row. ``project-away`` lets me drop just the noise (e.g. ``OrganizationId``, ``RecordType``) while keeping the rest. Best of both worlds when I'm still in discovery mode.